Lección 12 · Metodología forense e informe

Pregunta Guía	¿Cómo se convierte una solicitud ambigua en un trabajo forense que otra persona pueda revisar, repetir y defender?



Repaso: las fases NIST SP 800-86 (recolección, examen, análisis y reporte) están dentro de estas siete etapas; esta lección agrega lo que ocurre antes de recolectar y después de analizar.

Gemini Notebook

Leer una solicitud antes de actuar

Una solicitud de gerencia expresa una preocupación, no un encargo forense.

Problema	Frase de la solicitud	Pregunta de aclaración
Alcance	"Revisen todo su correo del último año"	¿Qué cuentas, qué intervalo y qué tipo de mensajes responden al objetivo?
Autoridad	"Revisen también el celular de la vendedora"	¿El equipo es personal? ¿Quién tiene autoridad para autorizarlo?
Método	"Préndanlo y vean qué tiene"	¿Quién decide encenderlo, con qué método y qué se altera al hacerlo?
Sesgo	"Sospecho de la vendedora"	¿Podemos formular las preguntas sobre la cuenta y el equipo, sin suponer quién lo hizo?
Plazo	"Lo necesito para mañana"	¿Sirve un primer informe parcial con sus límites declarados?
Privacidad	"Lean todos sus chats"	¿Qué mensajes personales o de terceros quedan excluidos?

Encender o apagar un equipo altera su estado: la decisión es técnica y requiere autorización.

Sesgo de confirmación: tendencia a buscar solo lo que confirma la sospecha inicial y a no ver lo que la contradice.

Gemini Notebook

Formular preguntas forenses

Cuatro rasgos de una pregunta forense

1. Se responde con evidencia que existe o puede obtenerse.
2. Tiene un objeto (qué información, cuenta o equipo) y un intervalo.
3. No presupone el resultado.
4. Permite responder “sí”, “no” o “no puede determinarse con estas fuentes”.

Pregunta débil	Pregunta forense
¿La vendedora vendió los precios?	¿Salió de la organización, mediante recursos corporativos, la lista de precios 2027 entre el 01-09 y el 07-09?
¿Qué hizo con su computador?	¿Qué registros del equipo CA-NB-04 muestran acceso al archivo de precios en ese intervalo?
¿A quién se lo mandó?	¿Qué destinatarios externos recibieron, desde la cuenta corporativa, mensajes con ese archivo en ese intervalo?

‘Saber quién lo hizo’ o ‘si nos traicionó’ preguntan por la intención de una persona. La evidencia técnica muestra acciones de cuentas y equipos; quién operaba la cuenta es otra pregunta.

Prioridad: primero las preguntas cuyas fuentes pueden perderse (volatilidad o retención) y las que responden directamente al objetivo autorizado.

Gemini Notebook

La autorización define el límite del trabajo

	Elemento	Qué responde	Ejemplo CERRO AZUL
1.	Objetivo	¿Para qué se investiga?	Determinar si la lista de precios 2027 salió de la organización
2.	Recursos incluidos	¿Qué fuentes pueden examinarse?	Notebook corporativo CA-NB-04, registro del servidor de correo, buzón corporativo
3.	Exclusiones	¿Qué no se toca?	Teléfono personal, mensajes personales, otros vendedores
4.	Intervalo	¿Qué periodo, en hora local y UTC?	01-09-2026 00:00 – 07-09-2026 23:59 hora de Chile (-04:00 hasta el 06-09, -03:00 después) = 01-09 04:00Z – 08-09 02:59Z
5.	Responsable	¿Quién dirige y responde?	Jefatura de TI
6.	Escalamiento	¿A quién se consulta si algo cambia?	Gerencia General y abogado externo
7.	Criterios de término	¿Cuándo se detiene o concluye?	Preguntas respondidas o imposibilidad documentada

Contrastar solicitud y autorización
- “Revisen el correo” → incluido → se ejecuta dentro del intervalo.
- “Revisen su celular” → excluido → no se ejecuta; se informa a quien solicitó.
- La autorización permite algo y a la vez lo excluye → el equipo no elige un criterio propio: escala al responsable.

Gemini Notebook

Proporcionalidad, minimización y datos no previstos



Proporcionalidad y Minimización

Proporcionalidad: la intrusión en datos y personas es acorde al objetivo.
Minimización: obtener y examinar solo lo necesario.
Un informe que incluye datos que no debía tratar pierde credibilidad.

Ejemplo Práctico

Ejemplo: TI exporta todos los mensajes del día, pero la autorización cubre solo los enviados a dominios externos.
El equipo registra el exceso en la bitácora, filtra al alcance y no examina el resto.

Gemini Notebook

Inventario forense e identificadores únicos

El inventario lista todas las fuentes identificadas, **incluso las que** no se adquirirán.

ID	Descripción	Custodio	Ubicación	Estado	Volatilidad o retención	Hash	Autorización
CA-EV01	Exportación del registro del servidor de correo	TI	Servidor de correo	Exportado	Retención 14 días	SHA-256 de la exportación	Incluido
CA-EV02	Notebook corporativo CA-NB-04	TI	Oficina comercial	Apagado	Estable; puede reasignarse	Pendiente de adquisición	Incluido
CA-EV03	Buzón corporativo	TI	Servicio de correo	En línea	Conservado 1 año	Pendiente	Incluido
CA-EV04	Teléfono personal de la vendedora	Titular	Con la persona	Desconocido	—	—	Excluido

Derivados:
CA-EV01 (original) → CA-EV01-T1 (copia de trabajo) → CA-EV01-S1 (salida). Toda salida se rastrea hasta su copia y la copia hasta su original. Un ID asignado no se reutiliza; si la fuente se descarta, se marca como descartada y se explica.

Errores típicos de un inventario: dos fuentes con el mismo ID, fuente sin estado o sin custodio, falta la retención, no se indica si está autorizada.

Gemini Notebook

Orden de adquisición: volatilidad, retención y dependencia

Volatilidad

Lo que desaparece antes se recolecta antes.
Repaso: RFC 3227.

Retención

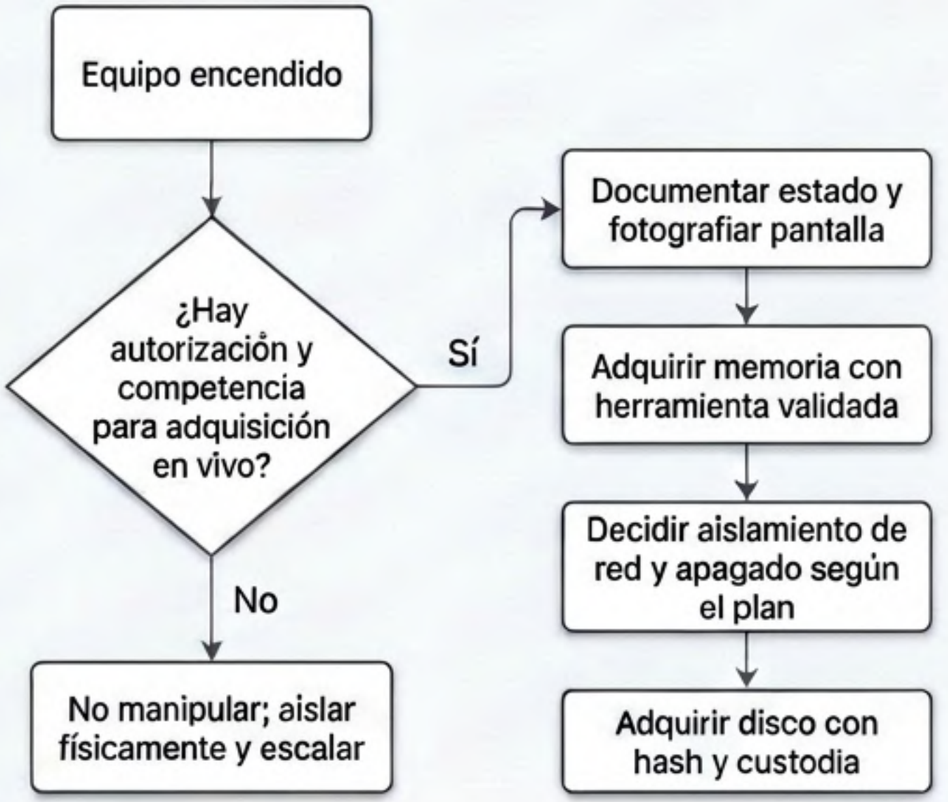
Los registros expiran según el servicio. Una auditoría cloud de 7 días puede ser más urgente que un disco apagado.

Dependencia

Una fuente puede necesitar otra para interpretarse. Si la segunda expira, ambas suben de prioridad.

Orden en CERRO AZUL

Orden	Fuente	Estado/Razón	Acción
1	Registro del servidor de correo	Retención de 14 días	Exportar enviados a dominios externos, con hash
2	Notebook CA-NB-04, apagado	Estable, pero puede reasignarse	Adquirir disco con bloqueador, hash y custodia
3	Buzón corporativo	Conservado 1 año	Exportar mensajes del intervalo a dominios externos



Apagarlo sin plan destruye memoria, conexiones y procesos, y con disco cifrado puede dejarlo inaccesible. Dejarlo encendido y conectado indefinidamente tampoco es correcto. En este curso no se adquiere memoria de equipos reales.

Gemini Notebook

Campos mínimos de una transferencia de custodia

	Campo Obligatorio	Por qué importa
1	Fecha y hora con zona (se recomienda UTC)	Ordena las transferencias contra otros registros temporales.
2	Identificador	Especifica exactamente la fuente transferida.
3	Hash completo y algoritmo	Demuestra que el contenido no cambió entre manos.
4	Entrega y Recibe	Establece los responsables antes y después.
5	Propósito	Justifica técnicamente el acceso a la evidencia.
6	Estado	Describe la condición física o lógica.
7	Firma / Control	Ambas partes reconocen la transferencia.

```
fecha_hora_utc,evidencia,sha256,entrega,recibe,proposito,estado
2026-09-03T14:20:00Z,CA-EV01,<SHA-256 completo de 64 caracteres>,TI,Analista A,Preservación,Exportación original sin escritura
```

Custodia lógica

- El manifiesto de hashes acompaña la entrega y se verifica al recibir.
- Cada copia de trabajo se verifica contra ese manifiesto antes de usarse.
- El hash de cada transferencia se calcula en el momento; no se copia del registro anterior.
- Las salidas del análisis también se registran con hash, porque serán anexos.

Gemini Notebook

Reparar una cadena de custodia sin inventar datos

Error Crítico	Riesgo de Trazabilidad	Corrección
Hora sin zona	Imposible ordenar respecto a eventos globales.	anotar la zona si consta en otro documento; si no, 'zona por confirmar'.
Entrega vacía	Tramo sin responsable asignado.	'entrega por confirmar' e indicar quién puede confirmarlo.
Hash parcial	Un prefijo no prueba la igualdad completa del contenido.	calcular el SHA-256 completo en el momento y compararlo con el manifiesto.
ID repetido	Confusión técnica entre dos fuentes distintas.	identificar la fuente con un dato inequívoco del inventario (descripción, ubicación o hash) y asignar un ID único.
Propósito vacío	Acceso injustificado a los datos.	'propósito por confirmar'; no suponer el motivo.

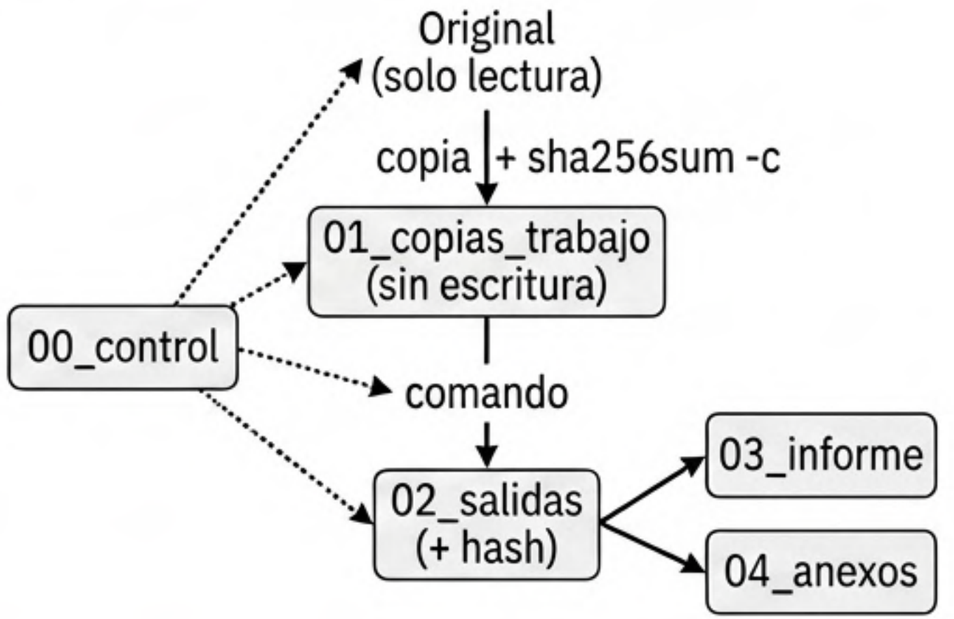
Antes y Después
Recibido: 03-09, EV-2, Analista B, 'copia'
Corregido: 03-09-2026 hora por confirmar (-04:00); CA-EV02-T1 copia de trabajo de CA-EV02; SHA-256 completo por calcular; entrega por confirmar; recibe Analista B; propósito examen; estado sin escritura

Nota final: Inventar una hora o un responsable convierte un problema de trazabilidad en un problema de veracidad. Un error propio no se borra: se agrega una fila que lo corrige. Un SHA-256 que coincide con el manifiesto prueba el contenido, no quién tuvo la evidencia en un tramo sin registro.

Gemini Notebook

Estructura del caso y copias protegidas

- **CA-CASO/**
  - **00_control**: bitácora, custodia y verificaciones de hash
  - **01_copias_trabajo**: copias verificadas, sin permiso de escritura
  - **02_salidas**: resultados de cada comando, que serán anexos
  - **03_informe**: borradores y versión final del informe
  - **04_anexos**: hashes de las salidas y material de respaldo



`sha256sum -c manifiesto.sha256` → recalcula el hash de cada archivo y lo compara con el manifiesto; muestra OK o FAILED. Ante FAILED: *detener* y avisar, nunca recalcular el manifiesto.
`chmod a-w 01_copias_trabajo/*` → quita el permiso de escritura a todos los usuarios (`a` = all, `-w` = sin escritura).
`date -u +%FT%TZ` → imprime la hora actual en UTC con formato `2026-09-03T14:20:00Z`, la que se usa en la custodia.

Se analizan copias verificadas y no los originales para que un error accidental no altere la evidencia.

Gemini Notebook

Matriz pregunta-fuente-técnica

Se completa antes de analizar: dice qué fuente responde cada pregunta, con qué técnica, qué se espera y qué no podrá afirmarse.

Pregunta	Fuente	Técnica	Resultado esperado	Limitación
P1	Registro servidor correo (CA-EV01)	Filtrar por cuenta, intervalo y adjunto	Mensajes a dominios externos	Registra nombres, no contenido
P1	Buzón corporativo (CA-EV03)	Extraer adjunto y comparar SHA-256	Igualdad de bytes	Igualdad no indica quién lo envió
P2	Notebook CA-NB-04 (CA-EV02)	Línea de tiempo y archivos recientes	Accesos al archivo	Las marcas de tiempo pueden alterarse; no identifica a la persona
(Sin pregunta)	Sistema de ventas	No examinar	Ninguno	Fuente disponible pero ninguna pregunta autorizada requiere su revisión

P1: ¿Se envió, desde la cuenta corporativa v.mella, la lista de precios 2027 a dominios externos entre el 01-09 y el 07-09?
P2: ¿Qué registros del equipo CA-NB-04 muestran acceso al archivo en ese intervalo?

La matriz evita "revisar todo". Si ninguna pregunta necesita una fuente, esa fuente no se examina aunque esté disponible.

Gemini Notebook

Cronología integrada en UTC

Hora original	Fuente y línea	Hora UTC	Evento
2026-09-04 11:01:40 (local -04:00, según ficha)	Notebook, línea de tiempo L88	15:01:40Z	Apertura de precios-2027.xlsx
2026-09-04T15:02:11Z	Servidor de correo L212	15:02:11Z	Mensaje enviado con adjunto
2026-09-04T11:02:13-04:00	Buzón, metadatos L9	15:02:13Z	Mensaje en carpeta Enviados

Comandos y explicaciones

```
awk -F, 'NR==1 || ($1>="2026-09-01 00:00:00" && $1<="2026-09-07 23:59:59") {print NR": "$0}'
01_copias_trabajo/timeline.csv
```

- -F, → separa columnas por coma
- $1 → primera columna (la fecha)
- >= y <= → compara texto; funciona porque el formato AAAA-MM-DD HH:MM:SS ordena igual que el tiempo
- NR==1 → conserva el encabezado
- print NR → muestra el número de línea, para citar "L88"

```
date -u -d '2026-09-04 11:01:40 -04:00'
```

→ convierte la hora local a UTC (15:01:40)

Reglas

- Se convierte una sola vez y se deja la hora original junto a la UTC para poder revisarla.
- Una fuente sin desfase escrito depende de la ficha técnica; esa dependencia se anota.
- Repaso: uniones directas, por valor y temporales.
- Registros fuera del filtro: excluir, escalar o pedir ampliación; no se rellenan huecos con suposiciones.

Gemini Notebook

Hallazgo reproducible

Repetibilidad: misma persona, mismo método y condiciones, mismo resultado.
Reproducibilidad: otra persona, mismo método sobre la misma evidencia, mismo resultado (ISO/IEC 27042). El informe aspira a la reproducibilidad.

Ficha de Hallazgo (H-01)	
Identificador	H-01
Pregunta	P1
Evidencia	CA-EV01 y su SHA-256 completo
Procedimiento	grep -nF 'precios-2027' 01_copias_trabajo/registro-correo.log | tee 02_salidas/correo-precios.txt
Salida	02_salidas/correo-precios.txt su SHA-256 se obtiene con sha256sum 02_salidas/correo-precios.txt
Resultado observado	la cuenta v.mella envió un adjunto precios-2027.xlsx a ventas@distribuidor.invalid a las 15:02:11Z
Interpretación	un archivo con ese nombre salió hacia un dominio externo
Confianza	media; una fuente y el contenido no se comparó por hash
Alternativa	archivo homónimo con otro contenido, o credencial usada por otra persona
Limitación	no identifica a la persona ni el contenido del adjunto

Niveles de Confianza	
Alta	varias fuentes independientes coinciden por uniones directas o por valor, integridad verificada, sin alternativa razonable.
Media	una fuente registra la acción y otra la corrobora parcialmente, o queda una alternativa razonable.
Baja	solo cercanía temporal, fuente única sin corroboración o integridad no verificable.

Sobreafirmación	Redacción acotada
La vendedora filtró los precios.	La cuenta v.mella envió un adjunto llamado precios-2027.xlsx a un dominio externo.
El adjunto era la lista de precios.	El adjunto tiene ese nombre; su contenido no fue comparado.
Queda demostrado.	Los registros son consistentes con...; confianza media porque...

Gemini Notebook

Arquitectura del informe forense

	Sección	Contenido	Lector principal
1.	Identificación del caso	código, solicitante, autorización, equipo, fechas, versión	Todos
2.	Resumen ejecutivo	qué se preguntó, qué se encontró, qué no se puede afirmar, qué decisión se necesita	Gerencia
3.	Alcance y preguntas	objetivo, recursos, intervalo, exclusiones, preguntas	Legal y gerencia
4.	Evidencia y custodia	inventario, hashes, estado, resumen de custodia	Revisor técnico y legal
5.	Metodología y herramientas	procedimientos, versiones, conversiones horarias	Revisor técnico
6.	Cronología	eventos en UTC con fuente y línea	Todos
7.	Hallazgos	hallazgos con confianza, alternativa y limitación	Revisor técnico
8.	Limitaciones	fuentes no disponibles, exclusiones, retención, atribución	Todos
9.	Conclusiones	respuesta a cada pregunta, sin exceder los hallazgos	Gerencia y legal
10.	Recomendaciones	preservaciones pendientes, ampliaciones a decidir	Gerencia
A.	Anexos	manifiestos, comandos, salidas con hash, custodia completa	Revisor técnico

Resumen ejecutivo (60 a 80 palabras)

- Se escribe al final y se ubica al principio.
- Sin tecnicismos.
- Cuatro elementos: qué se hizo, qué se observó, qué no puede afirmarse, qué decisión se necesita.

Se preservaron y verificaron el registro del servidor de correo y el notebook corporativo autorizados. En la semana revisada, la cuenta corporativa de ventas envió a un distribuidor externo un adjunto con el nombre de la lista de precios 2027. Todavía no se ha comprobado que ese adjunto sea la lista interna ni quién operaba la cuenta. Se necesita autorizar la comparación del adjunto conservado con la versión interna.

Nota: Si un hallazgo tiene confianza media, la conclusión no puede tener confianza alta.

Gemini Notebook

Revisión entre pares y comprobación final

La revisión entre pares busca:

- ☐ Una acción fuera de alcance
- ☐ Una fuente sin preservar o sin hash
- ☐ Un hallazgo sin evidencia citada
- ☐ Una conclusión que excede los datos

Si no encuentra un problema, escribe "no detectado" y explica qué revisó.

Otros controles de calidad

registrar la versión de cada herramienta y probarla con datos conocidos; por cada interpretación, preguntarse qué otra explicación es compatible con los mismos datos.

Comprobación final:

- ☐ Las preguntas no presuponen culpables
- ☐ El alcance cita la autorización y separa lo excluido de lo que se escala
- ☐ El inventario tiene IDs únicos y el orden considera volatilidad y retención
- ☐ Ninguna fila de custodia inventa responsables, horas ni hashes
- ☐ Se trabajó sobre copias verificadas y sin escritura
- ☐ La cronología está en UTC y cita archivo y línea
- ☐ El hallazgo incluye comando, salida con hash, confianza, alternativa y limitación
- ☐ La conclusión habla de cuentas y equipos, no de culpabilidad

Gemini Notebook